Capstone project

NovaTech Security Report

Student Name	Ashogbon Ayomikun Abdulazeez
Assessment date	April 1st 2026

1. Executive Summary

This report presents the findings of my cybersecurity assessment conducted on the NovaTech internal network. The assessment examined the network infrastructure, investigated SOC alerts, analysed penetration testing results, identified security vulnerabilities, evaluated risk levels, and produced actionable recommendations.

Network Overview: The NovaTech internal network (192.168.10.0/24) consists of five devices — a Router (192.168.10.1), Employee Workstation (192.168.10.15), Web Server (192.168.10.20), File Server (192.168.10.25), and Database Server (192.168.10.30). Suspicious external IPs (203.0.113.45 and 185.199.110.153) were observed communicating with the Web Server over HTTP Port 80, indicating potential reconnaissance or active attack activity
.
SOC Alert Investigation: Multiple failed login attempts and unusual authentication patterns were detected on the Web Server, consistent with a Brute-Force attack originating from an external IP address. Immediate containment actions were recommended including isolating the Web Server, disabling the affected account, blocking the attacker IP at the firewall, and restoring from a clean backup.

Vulnerability Findings: Several critical weaknesses were identified across the environment. The Web Server is running an outdated version of Apache (2.4.29). The Database Server uses weak default credentials (root/root), making it accessible to attackers. Anonymous FTP login is enabled on the File Server, allowing unauthenticated access to company documents. No Multi-Factor Authentication is enforced on any system, and the network lacks segmentation — meaning a single compromised device can lead to full network compromise. MySQL on Port 3306 is exposed with no external access restrictions.

Risk Assessment: The web server, Database Server, and File Server all carry a high risk rating. The network infrastructure carries a medium risk due to the absence of segmentation and endpoint detection. If the Web Server is compromised, the database Server (192.168.10.30) is the most likely next target, giving an attacker access to all internal application data.

Recommendations: To remediate the identified risks, NovaTech should immediately update Apache to the latest stable version, replace default credentials with strong passwords across all systems, enable Multi-Factor Authentication, disable anonymous FTP and migrate to SFTP, restrict MySQL Port 3306 to internal access only, implement network segmentation using VLANs, and deploy Endpoint Detection and Response (EDR) tooling on workstation.. Continuous SIEM monitoring should be maintained to detect and respond to future threats.

2. Network Overview and Findings

Network Fundamentals

Device	Purpose	IP Address
Router	Connects internal network to internet	192.168.10.1
Employee Workstation	Used by employees	192.168.10.15
Web Server	Hosts company website	192.168.10.20
File Server	Stores company documents	192.168.10.25
Database Server	Stores internal application data	192.168.10.30

Network Traffic Log Findings

- Suspicious external IPs detected: **203.0.113.45** and **185.199.110.153**
- Protocol in use: **HTTP — Port 80**
- Host communicating externally: **Web Server (192.168.10.20)**
- System exposed to the internet: **Web Server (192.168.10.20)**
- If the Web Server is compromised, the likely next target is the **Database Server (192.168.10.30)**

3. SOC Alert Investigation

Suspicious Activity Identified

Multiple failed login attempts and unusual authentication behaviour were detected, originating from an unknown external IP address targeting the Web Server.

Attack Type: Brute-Force Attack

Indicators of Compromise (IOCs)

- Multiple failed login attempts on the Web Server
- Suspicious external IP address communicating with internal hosts
- Unusual authentication patterns detected in logs

Immediate SOC Response Actions

- Isolate Web Server (192.168.10.20) from the network to prevent lateral movement
- Disable the affected user account
- Block the attacker's IP address on the perimeter firewall
- Change all login credentials on the affected system
- Check for opened backdoors or persistence mechanisms
- Restore system from a clean backup if integrity is compromised

Prevention Recommendations

- Enable Multi-Factor Authentication (MFA) across all systems
- Monitor SIEM for further alerts and correlate events
- Educate users about phishing and social engineering threats

4. Vulnerability Findings

Penetration Testing — Service & Port Analysis

The first service to investigate is **MySQL on Port 3306**. If an attacker gains access to the database, they immediately possess all company information which can be stolen, altered, or deleted entirely. Data breaches expose customer data, credentials, and internal records.

The service that should be publicly accessible is HTTP on Port 80, as it is required for hosting the company website.

The following services should be restricted: on the Web Server, MySQL and SSH should be restricted; on the File Server, SMB and FTP should be restricted; on the Database Server, MySQL should be restricted. Exposing these services creates unnecessary attack surface and risk of unauthorized access.

Identifying Security Weaknesses

- Weak default credentials (root/root) in use on the Database Server
- Web Server running an outdated version of Apache (2.4.29)
- No Multi-Factor Authentication (MFA) on any system
- Anonymous FTP login is allowed on the File Server
- The network is not segmented
- MySQL Port 3306 is exposed with no external access restrictions

Outdated Apache (2.4.29): Running legacy software is dangerous because vulnerabilities are publicly documented (CVEs) and exploit code is available. Attackers can execute arbitrary code, gain a reverse shell, or deface the public company website.

Weak Passwords (root/root): Simple credentials defeat authentication mechanisms. Attackers can easily guess these and gain immediate administrative control over the Database Server.

Anonymous FTP Login: Allowing anonymous access means anyone on the network can access the File Server without credentials — enabling attackers to read sensitive documents or upload malicious payloads.

5. Risk Assessment

Asset	Threat	Risk Level	Mitigation
Web Server	Brute-force / exploit of outdated Apache	HIGH	Implement MFA and update Apache
Database Server	Data breach / Data Theft	HIGH	Enforce strong passwords and restrict port 3306
File Server	Unauthorized access via Anonymous FTP	HIGH	Disable anonymous login and use secure file transfer protocol (SFTP)
Network Infrastructure	Lateral / Unusual Movement	MEDIUM	Segment network and deploy EDR on workstations

6. Security Recommendations

1. Update Apache Web Server

Upgrade from Apache 2.4.29 to the latest stable version immediately. Apply all available patches and enable automatic security updates.

2. Enforce Strong Password Policy

Remove all default credentials (root/root). Enforce a minimum 12-character password policy with complexity requirements across all systems.

3. Enable Multi-Factor Authentication (MFA)

Deploy MFA on all administrative interfaces, VPN access, and remote login portals to mitigate brute-force and credential stuffing attacks.

4. Disable Anonymous FTP / Migrate to SFTP

Disable anonymous FTP login on the File Server immediately. Migrate all file transfers to SFTP or FTPS with authenticated access only.

5. Restrict Port 3306 (MySQL)

Block external access to port 3306 at the firewall level. Database access should only be permitted from trusted internal application servers.

6. Implement Network Segmentation

Segment the network using VLANs to isolate the Web Server, Database Server, and File Server. Restrict inter-segment traffic with firewall rules.

7. Deploy EDR on Workstations

Install Endpoint Detection and Response (EDR) tooling on all employee workstations to detect and respond to anomalous behaviour.

8. Continuous SIEM Monitoring

Tune SIEM rules to alert on brute-force activity, unusual authentication patterns, and lateral movement indicators in real time.